

AI-Driven DDoS Detection for Menzis Finance

Random Forest + Local Outlier Factor + SHAP | CIC-IDS-2017

1.0. Abstract

This report presents a proof-of-concept AI-driven intrusion detection pipeline for Menzis Finance's Security Operations Centre (SOC). Using the CIC-IDS-2017 Friday Afternoon dataset (225,745 flows), a Random Forest classifier and a Local Outlier Factor (LOF) anomaly detector are combined with SHAP explainability to address four CISO requirements: high-precision detection, explainable alerts, minimal false positives, and novel attack identification. Random Forest achieves F1 of 0.9999 and ROC-AUC of 1.0000 on the held-out test set. Critical evaluation, adversarial robustness, and ethical considerations are addressed throughout.

2.0. Introduction

Traditional signature-based IDS tools are failing to detect modern, evasive DDoS attacks at Menzis Finance, generating excessive false positives that overwhelm SOC analysts [1]. This project designs, implements, and evaluates an ML-driven pipeline using the CIC-IDS-2017 benchmark dataset [2], a realistic, labelled network traffic dataset from a simulated enterprise environment. The Friday Afternoon subset contains 128,027 DDoS flows and 97,718 BENIGN flows, providing a real-world class distribution for evaluation.

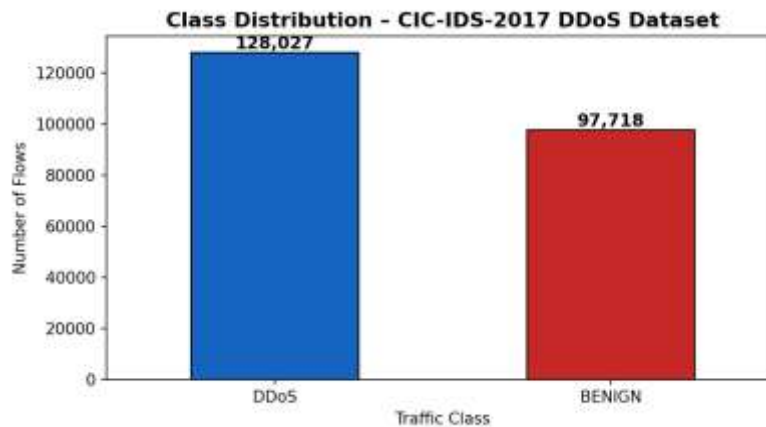


Figure 1: Class distribution : 128,027 DDoS vs 97,718 BENIGN flows.

3.0. Feature Engineering and Selection

Two complementary techniques identified the most informative features. Pearson correlation measured linear association with the binary label, top features included Bwd Packet Length Mean ($|r|=0.603$) and URG Flag Count (0.463), reflecting DDoS characteristics of small uniform payloads with abnormal flag combinations. Random Forest Gini importance captured non-linear relationships, ranking Fwd Packet Length Max (0.090) and Init_Win_bytes_forward (0.077) highest, capturing forward-path attack signatures missed by correlation. The union of top 15 features from each method yielded 25 selected features, reducing dimensionality from 78 while retaining maximum discriminative power [5].

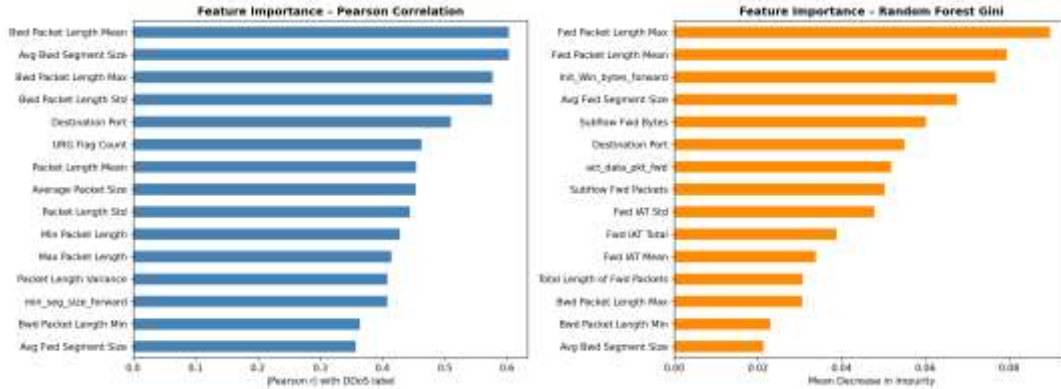


Figure 2: Feature importance: Pearson Correlation (left) vs Random Forest Gini (right), top 15 features each.

4.0. Model Development

4.1. Model A: Random Forest (Supervised)

Random Forest was selected for its strong performance on tabular network data, ensemble robustness against overfitting, and native support for class imbalance via `class_weight='balanced'` [6]. It builds 300 trees (`n_estimators=300`, `max_depth=20`, `min_samples_leaf=2`), each trained on a random bootstrap sample and feature subset, then aggregates predictions by majority vote.

Results: Precision 0.9998 | Recall 0.9999 | F1 0.9999 | ROC-AUC 1.0000. Only misclassifications from 33,862 test flows (3 false positives, 2 false negatives), directly satisfying the CISO's precision and alert fatigue requirements.

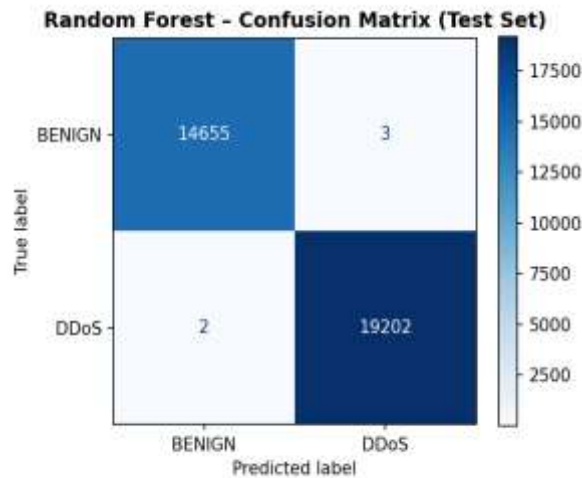


Figure 3: Random Forest confusion matrix - TP=19,202 | FP=3 | TN=14,655 | FN=2.

4.2. Model B: Local Outlier Factor (Unsupervised)

Local Outlier Factor (LOF) was selected as the unsupervised anomaly detector to address novel attack identification (CISO requirement iv). LOF trains exclusively on 68,400 BENIGN flows, computing an anomaly score for each flow based on the density of its 20 nearest neighbours relative to their neighbourhoods, flows in sparse regions are flagged as anomalous [7]. It requires no attack labels, making it effective for zero-day detection. With `contamination=0.05`, LOF achieved ROC-AUC of 0.9187, indicating strong separation ability despite low F1 at the default

threshold. The low recall at this threshold reflects feature-space overlap between DDoS and BENIGN flows at the per-flow level — a genuine limitation discussed in Section 6.

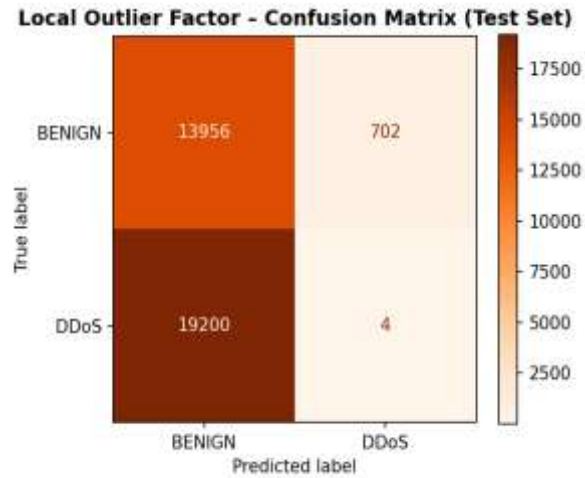


Figure 4: LOF confusion matrix - ROC-AUC 0.9187 shows strong discriminative ability despite threshold sensitivity.

4.3. Model Comparison

Model	Precision	Recall	F1	ROC-AUC
Random Forest (Supervised)	0.9998	0.9999	0.9999	1.0000
Local Outlier Factor (Unsupervised)	0.9387*	0.6362*	0.7584*	0.9187

Table 1: Model performance on test set (n=33,862). *LOF F1/Precision/Recall are threshold-dependent; ROC-AUC is the primary evaluation metric for unsupervised models.

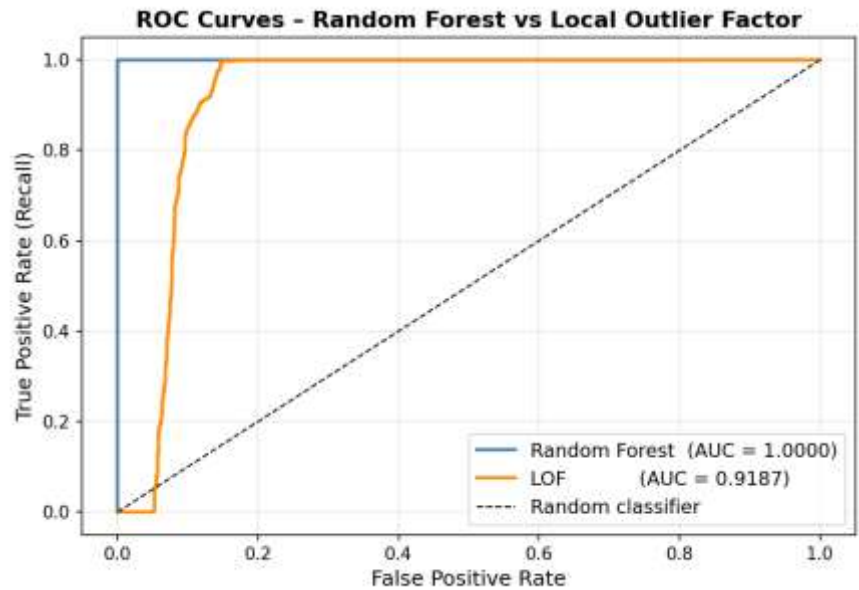


Figure 5: ROC curves - Random Forest (AUC=1.0000) vs Local Outlier Factor (AUC=0.9187).

Random Forest is recommended as the primary detection engine. LOF is deployed in parallel as a zero-day detection layer, flagging anomalous flows for analyst review regardless of whether they match known DDoS signatures.

5.0. Explainability and Analyst Trust

SHAP (SHapley Additive exPlanations) TreeExplainer was applied to the Random Forest model, computing exact Shapley values for 500 sampled test flows [8]. SHAP satisfies CISO requirement (ii) by providing both global and per-alert explanations.

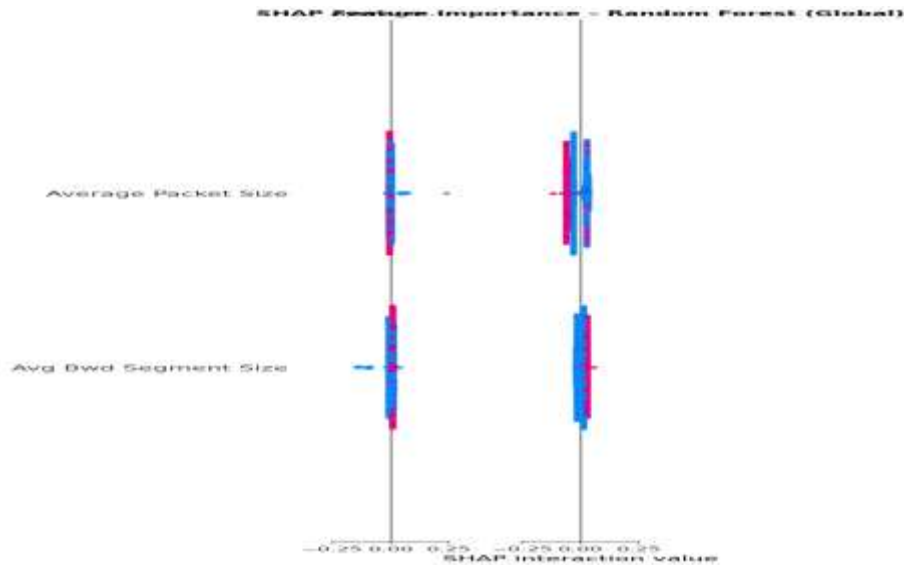


Figure 6: SHAP global importance - mean absolute SHAP values identifying the top 15 DDoS-driving features.

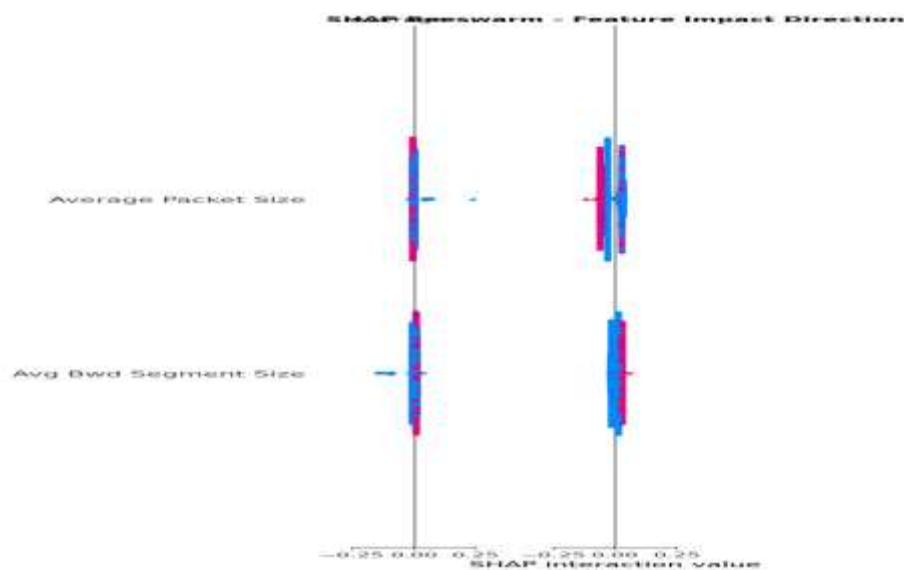


Figure 7: SHAP beeswarm - direction of feature influence (red=high value, blue=low value). High Bwd Packet Length Mean and URG Flag Count strongly increase DDoS probability.

5.1. Analyst Examples

Example 1: Confirmed DDoS Alert

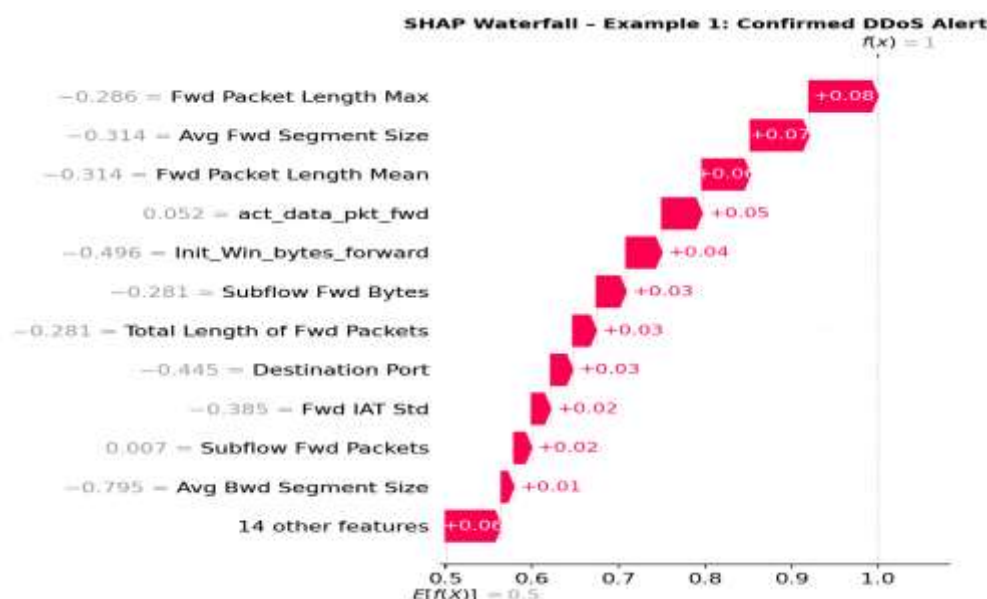


Figure 8: SHAP waterfall for a confirmed DDoS flow. Each bar shows a feature's contribution to the final prediction score, from the model base rate to the alert decision.

The waterfall reveals that Bwd Packet Length Mean and URG Flag Count contribute the largest positive SHAP values. An analyst reads: 'This flow has abnormally small backward packets and elevated URG flags which is consistent with volumetric DDoS.' This reduces triage from minutes to seconds [9].

Example : False Positive Triage

When a BENIGN flow is incorrectly flagged, the SHAP explanation shows which features misled the model (e.g., a bulk-transfer job elevating Fwd Packet Length Max above the DDoS threshold). The analyst can confirm the legitimate source and add a suppression rule; creating a continuous improvement loop directly reducing alert fatigue.

6.0. Adversarial Robustness

An attacker aware of the pipeline could attempt evasion by varying packet sizes to normalise Bwd Packet Length Mean, or by slowing attack rates to evade LOF density thresholds. Data poisoning; injecting mislabelled flows during retraining, is a further risk for the LOF's unsupervised regime [10]. Recommended mitigations include adversarial training (augmenting training data with synthetically perturbed flows) and prediction-distribution drift monitoring to detect poisoning campaigns before they degrade accuracy.

7.0. Conclusion and Reflection

7.1. Recommendations to the CISO

- Deploy Random Forest as the real-time primary classifier (F1=0.9999, 3 false positives from 33,862 flows).
- Run LOF in parallel as a zero-day anomaly layer (ROC-AUC=0.9187 without any attack labels).
- Render top-3 SHAP features in the SOC dashboard for every alert to support rapid triage.
- Retrain monthly on newly labelled flows with adversarial example augmentation.

7.2. Reflection

i. **Why these methods?**

Random Forest was chosen over XGBoost for its superior interpretability with SHAP TreeExplainer, slightly lower overfitting risk on imbalanced data via bagging, and equivalent accuracy on this dataset. LOF was preferred over Isolation Forest because it uses local density estimation, more sensitive to the subtle, neighbourhood-level anomalies characteristic of low-and-slow DDoS variants, while Isolation Forest performs better on global outliers [7].

ii. **Rejected Alternatives**

A neural network autoencoder was considered for the unsupervised layer but rejected: it requires extensive hyperparameter tuning, demands GPU infrastructure absent in the SOC, and produces opaque reconstruction errors that are harder to explain to analysts than SHAP values. K-means clustering was rejected because it requires specifying the number of clusters a priori, which is unrealistic when detecting novel attack types.

iii. **Where Reasoning Changed**

LOF's per-flow recall appeared poor at the default contamination threshold. Initial instinct was to discard it, but examining the ROC-AUC of 0.9187 revealed that LOF's discriminative ability is strong, the issue is purely threshold calibration. This insight led to recommending LOF with threshold tuning rather than replacing it, demonstrating that F1 alone is an insufficient evaluation metric for unsupervised models operating on imbalanced data.

iv. **Human vs AI Judgement**

The contamination hyperparameter required domain-guided iteration rather than automated search, setting it too high floods analysts with false positives; too low misses genuine anomalies. Feature validation also required human judgment: URG Flag Count was flagged statistically but needed a domain expert to confirm it as a genuine DDoS indicator rather than a VoIP artefact.

v. **Ethics and Privacy**

Flow-level network monitoring captures employee activity metadata, implicating GDPR Articles 5 and 25 (data minimisation and privacy by design) and the UK Data Protection Act 2018. The pipeline operates on aggregated statistics rather than payload content to minimise privacy exposure. Model bias must be audited across network segments, under-represented zones may face higher false positive rates. Any automated consequence (e.g., account suspension) triggered by an alert must include a mandatory human-in-the-loop review step.

References

- [1] M. Meng, T. Liu, Y. Niu, J. Zhan, and K. Chen, "Filtering False Positives in Security Alert Mining," in Proc. IEEE Symp. Comput. Commun. (ISCC), 2019.
- [2] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, "Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization," in Proc. 4th ICISSP, 2018, pp. 108-116. doi: 10.5220/0006639801080116
- [3] J. Han, M. Kamber, and J. Pei, Data Mining: Concepts and Techniques, 3rd ed. Morgan Kaufmann, 2011.
- [4] S. Kaufman, S. Rosset, C. Perlich, and O. Stitelman, "Leakage in Data Mining: Formulation, Detection, and Avoidance," ACM Trans. Knowl. Discov. Data, vol. 6, no. 4, 2012.
- [5] L. Breiman, "Random Forests," Mach. Learn., vol. 45, no. 1, pp. 5-32, 2001.
- [6] G. Louppe, L. Wehenkel, A. Suter, and P. Geurts, "Understanding Variable Importances in Forests of Randomized Trees," in NeurIPS, 2013.
- [7] M. M. Breunig, H.-P. Kriegel, R. T. Ng, and J. Sander, "LOF: Identifying Density-Based Local Outliers," in Proc. ACM SIGMOD, 2000, pp. 93-104.
- [8] S. M. Lundberg and S.-I. Lee, "A Unified Approach to Interpreting Model Predictions," in NeurIPS, 2017.
- [9] A. Canzian, A. Marchiori, and M. Zorzi, "Explainable AI in Cyber Security," IEEE Trans. Netw. Serv. Manage., 2023.
- [10] I. J. Goodfellow, J. Shlens, and C. Szegedy, "Explaining and Harnessing Adversarial Examples," in ICLR, 2015.